Phishing Detection & Awareness Report

PREPARED FOR: FUTURE INTERNS (CYBER SECURITY TASK 2, 2026)
WRITTEN BY: MULUMBWA MATIMELO
DATE: APRIL 1, 2026

Executive Summary

This report analyzes common phishing email tactics and provides a framework for user awareness. By examining real-world examples and using industry-standard analysis tools, this report outlines the key indicators of phishing attempts. The goal is to empower employees to identify and report threats, significantly reducing the organization's risk of a successful cyber attack..

Methodology & Tools Used

The analysis in this report was conducted using the following methodology and tools:

- **Email Collection:** Public datasets and repositories (as listed in the task) were used as sources for real phishing email samples.
- **Header Analysis:** The authenticity of email origins was examined using:
  - **Google Admin Toolbox Messageheader:** https://toolbox.googleapps.com/apps/messageheader/
  - **MXToolbox Email Header Analyzer:** https://mxtoolbox.com/EmailHeaders.aspx
- **Link & Domain Inspection:** Suspicious URLs were analyzed safely using browser-based tools to examine destination domains without directly visiting them.
- **Documentation:** Findings were documented in this structured report (Google Docs/MS Word/PDF format).

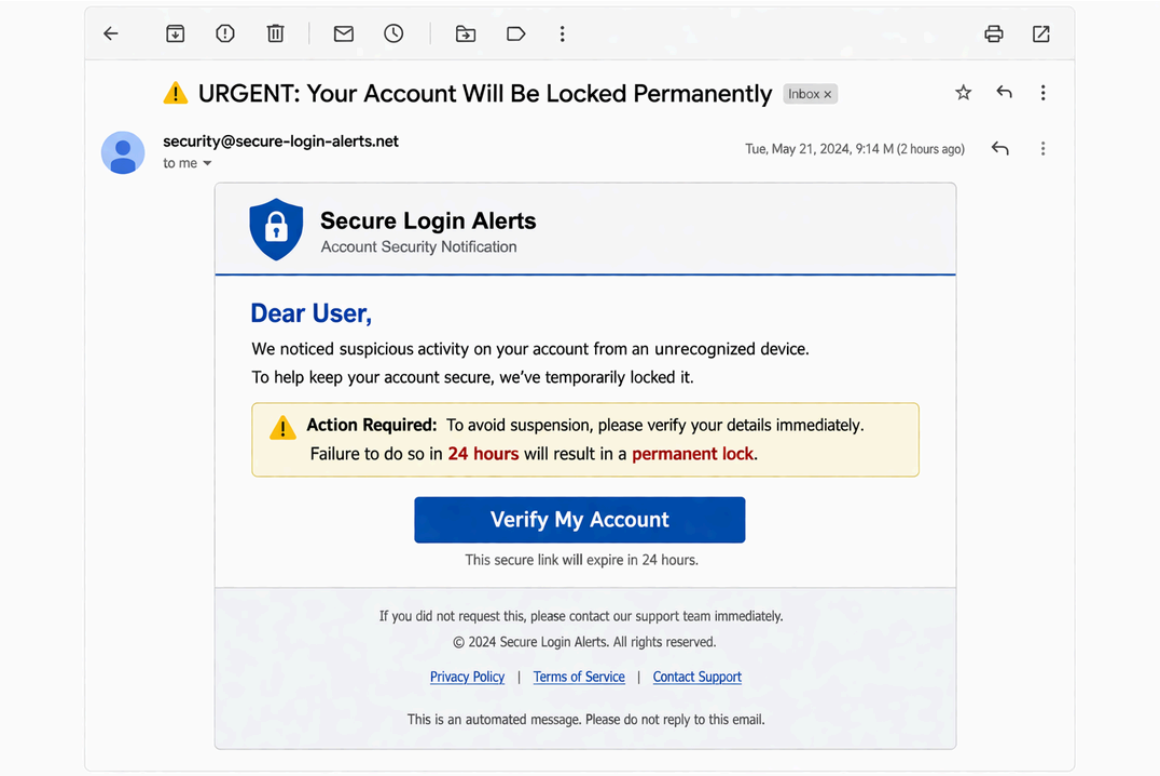
Phishing Email Analysis

For this analysis, we examine a common type of phishing email: the "Account Suspension" scam. This type of email exploits user fear of losing access to a critical service.

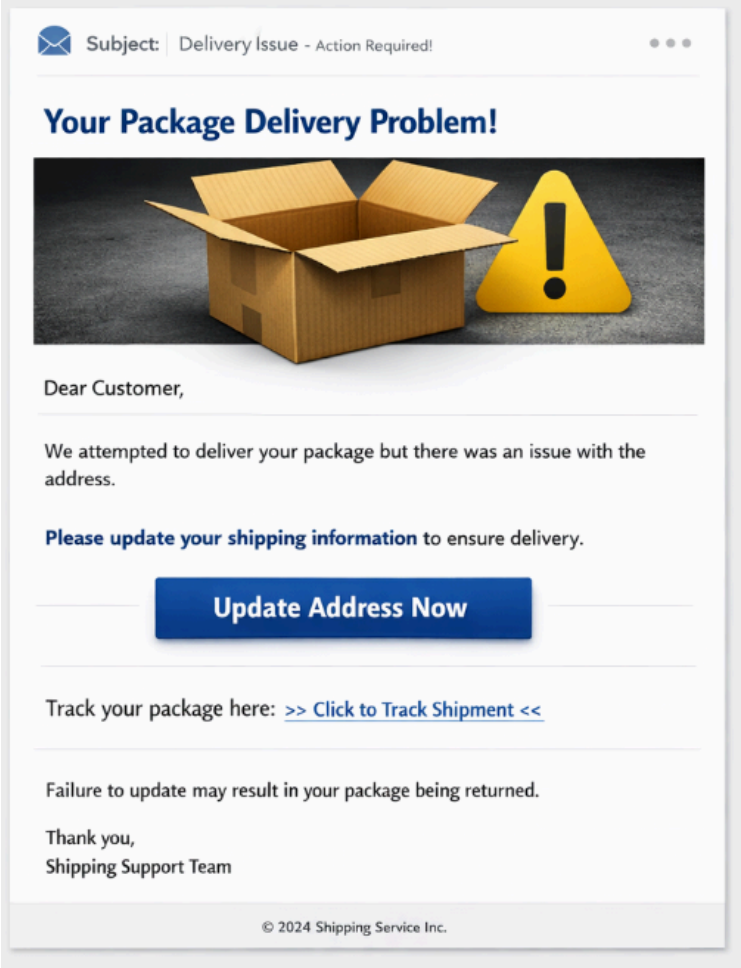
Email Sample 1: "Account Locked" Scam

Email Field	Content
From	deals@exclusive-offers-center[.]com
Subject	Exclusive 70% Discount – Claim Before It Expires!
Body (Excerpt)	“Congratulations! You’ve been selected for an exclusive 70% discount on your next purchase. Claim your limited-time offer now by verifying your account details—this deal expires in 24 hours.”

Email Sample 2: "Account Locked" Scam



Email Sample 3: "Update Address" Scam



Header Analysis

Using the **Google Admin Toolbox**, the email header was analyzed. Key findings:

- **Return-Path:** The Return-Path domain (bounce.suspicious-mail[.]biz) did not match the From domain, a common sign of spoofing.
- **SPF/DKIM:** SPF (Sender Policy Framework) and DKIM (DomainKeys Identified Mail) checks failed or showed a "softfail," indicating the email was not sent from an authorized server for the claimed domain.
- **Source IP:** The originating IP address was traced to a hosting provider known for being used in spam campaigns, not the legitimate company's corporate IP range.

Link & URL Inspection

The email contained a single, prominent button labeled "**Verify My Account**". The underlying link was inspected using a browser's developer tools.

- **Displayed Text:** https://secure-login-alerts[.]net/verify
- **Actual Destination:** http://malicious-verification-page[.]biz/steal-login.php
- **Risk Indicator:** The actual link points to a completely different, recently registered domain that uses an uncommon top-level domain (.biz), which is a major red flag.

Risk Classification

Email Component	Indicator	Risk
Sender Domain	Spoofed, mismatched Return-Path, failed SPF/DKIM.	**Phishing**
Subject Line	Creates urgency ("URGENT", "24 hours") and fear ("permanent lock").	**Phishing**
Greeting	Generic ("Dear User"), not personalized.	**Phishing**
Link URL	Text does not match the actual destination; destination is on a suspicious domain.	**Phishing**
Overall Classification	**Confirmed Phishing Attempt**	**High Risk**

How the Attack Works: Simple Explanation

This is a classic example of a **credential harvesting attack**.

1. **Bait:** The attacker creates a sense of panic, implying you are about to lose access to an important account (e.g., email, company portal).
2. **Hook:** It asks you to "verify" your details. The link in the email does not go to the real company.
3. **Trap:** If clicked, the link opens a fake website that looks identical to the legitimate login page. When you enter your username and password, the information is sent directly to the attacker.
4. **Result:** The attacker now has your credentials and can potentially access your real account and company network.

Prevention & Awareness Guidelines

Do's

- **Pause and Verify:** If an email creates a sense of urgency, stop. Do not click anything. Contact the supposed sender using a phone number or website you know is legitimate (do not use any contact info from the suspicious email).
- **Hover Over Links:** Before clicking any link, hover your mouse cursor over it. Your browser will show the true destination. If it looks suspicious or unrelated, do not click.

- **Report It:** If you receive a suspicious email, immediately report it to your IT or Security team using the designated process (e.g., a "Report Phishing" button).
- **Enable Multi-Factor Authentication (MFA):** Even if an attacker steals your password, MFA provides a critical second layer of defense.

Don'ts

- ✘ **Don't Click on Suspicious Links:** Never click links or download attachments from unsolicited or unexpected emails.
- ✘ **Don't Enter Credentials:** Do not enter your password on a webpage you navigated to from an email link.
- ✘ **Don't Ignore Warnings:** Pay attention to browser warnings about a site being unsafe or suspicious.
- ✘ **Don't Assume:** An email from a known name is not automatically safe. The sender's account could have been compromised.

Conclusion

Phishing remains one of the most persistent and effective threats facing organizations today, not because technical controls are inadequate, but because attackers increasingly exploit the human element. This report has demonstrated that even a seemingly simple email—such as the "Account Locked" scam analyzed here contains multiple red flags that, when properly understood, can be easily identified and avoided.